

Clase 170 — Active Directory: enumeración

Parte: **7 — Red Team y operaciones ofensivas** · Fuente: *The Hacker Recipes (AD) / Operator Handbook*

 Duración estimada: **110 min** · Nivel: **Avanzado**

Objetivo

Aprender a enumerar un dominio de Active Directory desde una posición de foothold: usuarios, grupos, equipos, políticas, confianzas, SPNs y relaciones. La enumeración es el 80% del trabajo en AD: cuanto mejor entiendas la estructura del dominio, más limpio y dirigido será el ataque. El alumno montará un AD lab (o usará GOAD) y lo mapeará.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Montar** un laboratorio de Active Directory (o desplegar GOAD).
2. **Enumerar** usuarios, grupos, equipos y GPOs con herramientas nativas y de terceros.
3. **Identificar** SPNs, cuentas privilegiadas y relaciones de confianza.
4. **Consultar** LDAP de forma eficiente y sigilosa.
5. **Documentar** la superficie del dominio para planificar el ataque.

Temas

#	Tema	Por qué importa
1	Estructura de AD	Dominios, OUs, forest, confianzas
2	LDAP y objetos	El "lenguaje" de consulta de AD
3	Enumeración de usuarios/grupos	Mapa de identidades y privilegios
4	SPNs y cuentas de servicio	Base de Kerberoasting (Clase 171)
5	GPOs y ACLs	Fuente de rutas de escalado
6	Confianzas de dominio/forest	Movimiento entre dominios
7	Sigilo en la enumeración	Evitar disparar alertas

Definiciones y características

- **Active Directory**: servicio de directorio de Microsoft para gestionar identidades y recursos. Característica: LDAP + Kerberos como columna vertebral.
- **LDAP**: protocolo de consulta del directorio. Característica: permite enumerar casi todo con una cuenta de dominio válida.
- **SPN (Service Principal Name)**: identificador de un servicio ligado a una cuenta. Característica: habilita Kerberoasting.

- **GPO (Group Policy Object):** política aplicada a OUs/equipos. Característica: mal configurada, ofrece escalado.
- **ACL / ACE:** permisos sobre objetos de AD. Característica: relaciones abusables (GenericAll, WriteDACL).
- **Trust (confianza):** relación entre dominios/forests. Característica: puede permitir saltar de un dominio a otro.

Herramientas y preparación

- **AD lab:** un DC Windows Server + 1–2 workstations, o desplegar **GOAD**.
- **PowerView** (PowerShell), **NetExec (nxc)**, **ldapsearch**, **BloodHound** collectors (Clase 173).
- **Impacket** (**GetADUsers.py**, **GetUserSPNs.py**) desde Linux.
- Una cuenta de dominio de bajo privilegio para partir del foothold.

⚠️ Todo se realiza contra tu propio laboratorio de AD (o GOAD). Enumerar un dominio ajeno sin autorización es acceso no autorizado. GOAD está diseñado precisamente para practicar esto de forma legal.

Laboratorio guiado

1. **Despliega el lab.** Levanta GOAD o tu DC + workstations. Verifica resolución DNS al dominio (ej. `lab.local`).
2. **Enumera con nxc:** `nxc smb 10.10.10.10 -u user -p 'pass' --users --groups` para listar usuarios y grupos.
3. **PowerView desde Windows.** Importa el módulo y ejecuta `Get-DomainUser`, `Get-DomainGroupMember "Domain Admins"`, `Get-DomainComputer`.
4. **Busca SPNs:** con Impacket `GetUserSPNs.py lab.local/user:pass -dc-ip 10.10.10.10` para localizar cuentas de servicio (insumo de la próxima clase).
5. **Consulta LDAP directa:** `ldapsearch -x -H ldap://10.10.10.10 -D 'user@lab.local' -w pass -b 'DC=lab,DC=local' '(objectClass=user)'`.
6. **Mapea confianzas:** `Get-DomainTrust` y anota relaciones entre dominios del forest.
7. **Recoge para BloodHound.** Ejecuta el collector (`SharpHound` / `bloodhound-python`) para el análisis de rutas de la Clase 173, y documenta cuentas privilegiadas y ACLs interesantes.

Ejercicios

1. Lista todos los miembros de "Domain Admins" del lab con dos herramientas distintas.
2. Encuentra 3 cuentas con SPN y explica por qué son interesantes.
3. Consulta por LDAP los usuarios con `PASSWD_NOTREQD` o `DONT_REQUIRE_PREAUTH`.
4. Enumera las GPOs del dominio y a qué OUs aplican.
5. Mapea las confianzas del forest y dibújalas.
6. Compara el ruido (telemetría) de PowerView vs consultas LDAP puntuales.



Reto verificable

Produce un **mapa del dominio de tu AD lab**: usuarios privilegiados, cuentas con SPN, GPOs relevantes, confianzas y al menos una relación ACL potencialmente abusable, recogido además con un collector de BloodHound. **Criterio de aceptación**: entregas un documento/diagrama con esos cinco elementos, cada dato verificable en el lab, y un archivo de recolección listo para importar en BloodHound.



Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
LDAP no responde	DNS mal configurado o credenciales inválidas; verifica dominio y cuenta
PowerView bloqueado por AMSI	Import detectado; aplica lo visto en la Clase 169 en el lab
No aparecen SPNs	No hay cuentas de servicio con SPN registrado; revisa el diseño del lab
Enumeración muy ruidosa	Consultas masivas; usa peticiones dirigidas y espaciadas
El collector falla	Falta conectividad al DC o permisos; ejecuta con la cuenta correcta



Preguntas frecuentes

? **¿Necesito ser admin para enumerar AD?** No. Con **cualquier** cuenta de dominio válida se puede enumerar la mayor parte del directorio: ese es el diseño de AD y la razón de su exposición.

? **¿PowerView o BloodHound?** Ambos: PowerView para consultas puntuales interactivas; BloodHound para visualizar relaciones y rutas de ataque (Clase 173).

? **¿Qué es GOAD?** Game of Active Directory: un laboratorio vulnerable y reproducible pensado para practicar ataques a AD de forma legal en tu propia máquina.



Referencias

- The Hacker Recipes — *AD enumeration*. <https://www.thehacker.recipes/>
- GOAD. <https://github.com/Orange-Cyberdefense/GOAD>
- PowerSploit/PowerView. <https://github.com/PowerShellMafia/PowerSploit>
- Impacket. <https://github.com/fortra/impacket>



Siguiente clase

Clase 171 - Active Directory: Kerberoasting y ataques a Kerberos